



SANITIZED PUBLIC CASE STUDY VERSION

Mobile Application Security Assessment Report

Android Mobile Application Security Review

PREPARED BY	Mantirix Cybersecurity Solutions LLC
ASSESSMENT TYPE	Mobile Application Security Assessment
PLATFORM	Android
CLASSIFICATION	Sanitized Public Portfolio Version
VERSION	1.0

TABLE OF CONTENTS

1.	Executive Summary
2.	Scope of Assessment
3.	Testing Methodology
4.	Tools Used
5.	Risk Rating Methodology
6.	Findings Summary
7.	Detailed Findings
8.	Remediation Roadmap
9.	Conclusion
10.	Public Portfolio Disclaimer



1. Executive Summary

Mantirix Cybersecurity Solutions LLC conducted a comprehensive security assessment of a modern Android mobile application to evaluate the security posture of the application's authentication mechanisms, local storage practices, network communications, cryptographic implementations, and overall mobile security architecture.

Testing included a combination of:

- Static APK analysis
- Dynamic traffic interception
- Authentication flow review
- Manual code review
- Mobile configuration analysis
- Security architecture evaluation

The assessment identified multiple vulnerabilities across authentication handling, transport security, cryptographic usage, local data storage, and dependency management.

The most significant findings included:

- Weak OAuth security configuration
- Insecure token handling practices
- Weak cryptographic implementations
- Potential insecure storage of sensitive application data
- Transport-layer security weaknesses
- Mobile application configuration weaknesses
- Supply-chain exposure through third-party dependencies

Overall, the application demonstrated a **moderate-to-high security risk profile** requiring remediation prior to large-scale production deployment.

RISK CATEGORY	FINDINGS COUNT	OVERALL POSTURE
High Severity	3	Immediate Remediation Required
Medium Severity	9	Pre-Release Remediation Required
Low Severity	2	Remediation Recommended

Informational	1	Security Hardening Opportunity
---------------	---	--------------------------------



2. Scope of Assessment

In Scope

- Android mobile application package analysis
- Authentication and session handling review
- Local storage and caching analysis
- HTTPS and WebSocket communication review
- Mobile manifest and configuration review
- Observable API interaction analysis
- OAuth authentication flow review
- Dependency and package analysis

Out of Scope

- Backend infrastructure penetration testing
- Cloud infrastructure review
- Social engineering
- Physical device compromise testing
- iOS application testing

3. Testing Methodology

Phase 1 — Reconnaissance

The application package was acquired and analyzed to identify high-level architecture, permissions, and observable attack surfaces.

Phase 2 — Static Analysis

Automated mobile security analysis tools were used to identify: insecure permissions, weak cryptography, insecure storage patterns, manifest configuration weaknesses, exported components, and dependency risks.

Phase 3 — APK Decompilation & Manual Review

The application package was decompiled to review: authentication logic, session handling, network communication logic, token handling patterns, cryptographic implementation, and mobile security controls.

Phase 4 — Dynamic Traffic Analysis

Application traffic was intercepted within a controlled Android testing environment using trusted proxy certificates to analyze: HTTPS traffic, authentication flows, session behavior, API communication, and WebSocket communication.

Phase 5 — Findings Consolidation

Findings were validated, deduplicated, categorized by severity, and documented with remediation recommendations.

4. Tools Used

TOOL	PURPOSE
MobSF	Mobile static security analysis
Burp Suite	HTTP/HTTPS traffic interception
HTTP Toolkit	Mobile traffic analysis
Android Studio Emulator	Controlled Android testing
ADB	Android device interaction
Kali Linux	Security testing environment
Oracle VirtualBox	Virtualized testing infrastructure



5. Risk Rating Methodology

SEVERITY	DESCRIPTION
HIGH	Direct risk of authentication compromise, sensitive data exposure, or account takeover
MEDIUM	Significant security weakness requiring remediation before production release
LOW	Limited direct impact but contributes to reduced security posture
INFORMATIONAL	Security hardening opportunity or best-practice recommendation

6. Findings Summary

FINDING ID	TITLE	SEVERITY
MANT-MOB-001	Weak OAuth Security Configuration	HIGH
MANT-MOB-002	Insecure Token Handling Mechanism	HIGH
MANT-MOB-003	Insecure WebSocket Communication Handling	HIGH
MANT-MOB-004	Sensitive Authentication Data Exposure Risk	MEDIUM
MANT-MOB-005	Deep Link / Redirect Handling Weakness	MEDIUM
MANT-MOB-006	Insecure Mobile Backup Configuration	MEDIUM
MANT-MOB-007	Potential Insecure Local Storage Practices	MEDIUM
MANT-MOB-008	Weak Cryptographic Algorithm Usage	MEDIUM
MANT-MOB-009	Insecure Random Number Generation	MEDIUM
MANT-MOB-010	Sensitive Authentication Data Handling Risks	MEDIUM
MANT-MOB-011	Embedded Development Credentials	MEDIUM
MANT-MOB-012	Third-Party Dependency Exposure	MEDIUM
MANT-MOB-013	Certificate Pinning Not Enforced	INFORMATIONAL
MANT-MOB-014	Exported Android Components	LOW

MANT-MOB-015	Legacy Android Version Support Risks	LOW
--------------	--------------------------------------	-----



7. Detailed Findings

MANT-MOB-001 — Weak OAuth Security Configuration

Severity: **HIGH**

DESCRIPTION

The application utilized a weaker OAuth security configuration that reduced the effectiveness of authorization code protection mechanisms.

IMPACT

An attacker intercepting authentication traffic under specific conditions may potentially abuse authorization flows or weaken authentication protections.

REMEDIATION

- Enforce modern OAuth security standards
- Implement SHA-256 based PKCE protection
- Reject insecure authentication methods

MANT-MOB-002 — Insecure Token Handling Mechanism

Severity: **HIGH**

DESCRIPTION

Authentication tokens were handled using insecure communication patterns that may expose tokens to unintended recipients.

IMPACT

Potential token theft and account compromise if exploited successfully.

REMEDIATION

- Restrict token communication origins
- Validate trusted origins
- Minimize token exposure within application communication flows

MANT-MOB-003 — Insecure WebSocket Communication Handling

Severity: **HIGH**

DESCRIPTION

The application exposed authentication information within WebSocket communication patterns and permitted insecure transport fallback behavior.

IMPACT

Potential session interception or sensitive data exposure over untrusted networks.

REMEDIATION

- Enforce encrypted WebSocket communication only
- Use temporary session tokens
- Eliminate insecure fallback transport logic

MANT-MOB-004 — Sensitive Authentication Data Exposure Risk

Severity: **MEDIUM**

DESCRIPTION

Authentication-related data may appear within redirect or callback handling processes.

IMPACT

Potential replay or interception risk under specific conditions.

REMEDIATION

- Minimize logging of authentication data
- Reduce token exposure windows
- Harden redirect validation mechanisms

MANT-MOB-005 — Deep Link Handling Weakness

Severity: **MEDIUM**

DESCRIPTION

The application used mobile deep linking mechanisms that may be vulnerable to interception by unauthorized applications.

IMPACT

Potential interception of authentication-related flows.

REMEDIATION

- Implement verified application linking

- Restrict unauthorized URI handling
- Harden mobile redirect validation

MANT-MOB-006 — Insecure Mobile Backup Configuration

Severity: **MEDIUM**

DESCRIPTION

Application backup functionality may permit extraction of sensitive application data under certain device conditions.

IMPACT

Potential local extraction of cached application data.

REMEDIATION

- Disable unnecessary backup functionality
- Restrict sensitive data inclusion in backups

MANT-MOB-007 — Potential Insecure Local Storage Practices

Severity: **MEDIUM**

DESCRIPTION

Sensitive application data may be stored or logged insecurely within local storage mechanisms.

IMPACT

Potential session or credential exposure on compromised devices.

REMEDIATION

- Use secure encrypted storage APIs
- Remove sensitive logging
- Audit local storage usage

MANT-MOB-008 — Weak Cryptographic Algorithm Usage

Severity: **MEDIUM**

DESCRIPTION

Weak legacy cryptographic algorithms were identified within the application.

IMPACT

Reduced cryptographic security and increased risk of compromise.

REMEDIATION

- Replace weak algorithms with modern cryptographic standards
- Use SHA-256, SHA-512, bcrypt, or Argon2 where appropriate

MANT-MOB-009 — Insecure Random Number Generation

Severity: **MEDIUM**

DESCRIPTION

Non-cryptographically secure random number generation was identified.

IMPACT

Predictable security-sensitive values may weaken authentication security.

REMEDIATION

- Use cryptographically secure random generators
- Eliminate insecure randomization methods

MANT-MOB-010 — Sensitive Authentication Data Handling Risks

Severity: **MEDIUM**

DESCRIPTION

Sensitive authentication-related data structures may not be sufficiently protected at rest.

IMPACT

Potential credential or session exposure during database compromise scenarios.

REMEDIATION

- Encrypt sensitive authentication data
- Enforce secure password hashing
- Implement token rotation policies

MANT-MOB-011 — Embedded Development Credentials

Severity: **MEDIUM**

DESCRIPTION

Development or test credentials were identified within application-related resources.

IMPACT

Potential unauthorized access if deployed improperly.

REMEDIATION

- Remove embedded credentials
- Use secure secret management solutions

MANT-MOB-012 — Third-Party Dependency Exposure

Severity: **MEDIUM**

DESCRIPTION

The application utilized numerous third-party dependencies that increase supply-chain risk exposure.

IMPACT

Potential compromise through vulnerable or malicious dependencies.

REMEDIATION

- Conduct regular dependency audits
- Remove unused packages
- Monitor dependencies continuously

MANT-MOB-013 — Certificate Pinning Not Enforced

Severity: **INFORMATIONAL**

DESCRIPTION

The application did not enforce SSL certificate pinning during testing.

IMPACT

Reduced resistance against advanced interception attacks on compromised networks.

REMEDIATION

- Implement SSL certificate pinning in production builds

MANT-MOB-014 — Exported Android Components

Severity: **LOW**

DESCRIPTION

Certain Android application components were externally accessible.

IMPACT

Potential misuse by other local applications.

REMEDIATION

- Restrict exported components where unnecessary

MANT-MOB-015 — Legacy Android Version Support Risks

Severity: **LOW**

DESCRIPTION

Support for older Android versions may reduce the application's overall security baseline.

IMPACT

Exposure to older platform-level vulnerabilities.

REMEDIATION

- Increase minimum supported Android SDK version where feasible



8. Remediation Roadmap

Immediate Priority

- Harden OAuth security configuration
- Secure token communication handling
- Enforce encrypted transport mechanisms

Pre-Release Priority

- Improve local storage security
- Replace weak cryptography
- Remove embedded credentials
- Audit third-party dependencies
- Restrict mobile backup functionality

Future Security Hardening

- Implement certificate pinning
- Reduce exported Android components
- Increase minimum Android SDK requirements

9. Conclusion

The mobile application demonstrated several meaningful security weaknesses across authentication handling, transport security, cryptography, and local data protection.

While no catastrophic remote code execution vulnerabilities were identified during this engagement, the collective impact of the identified findings significantly weakens the application's security posture and should be addressed prior to production-scale deployment.

Mantirix Cybersecurity Solutions LLC recommends:

- Remediation of all High and Medium severity findings
- Implementation of secure development lifecycle practices
- Recurring dependency auditing
- Regular penetration testing

- Secure code review processes
- Ongoing mobile application security assessments

10. Public Portfolio Disclaimer

This report represents a sanitized public case study version of a mobile application security assessment. All sensitive information, proprietary implementation details, internal infrastructure references, credentials, endpoints, and identifying client-specific security details have been removed or generalized for public portfolio presentation purposes.

The purpose of this document is to demonstrate security assessment methodology, technical capability, and remediation-focused reporting practices without exposing confidential client information.

DISCLAIMER

This document is a sanitized public portfolio case study. No real client data, credentials, endpoints, or proprietary information is contained within this report. All findings are generalized for professional portfolio demonstration purposes only.

